LABORATUVAR 5 · AHC RAPID DRILLING 4014 SÜRÜMÜ

5 SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Makine: AHC Makine RAPID DRILLING 4014 · CNC Çoklu Delik Delme / Freze İşleme Merkezi (AİMSAD)

Ad Soyad **Grup** **Tarih:** 24.10.2026

Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: bileşen **var**, sürüm **etkileniyor**, açık **ulaşılabilir**.

Verilen zafiyet kaydı

Bileşen	Component X (PLC firmware kütüphanesi) — 4014 karşılığı: TPA CNC kontrol / sürücü firmware kütüphanesi
Sürüm	2.4
CVE	CVE-XXXX-XXXX
Önem	Critical (CVSS 9.8)
Yama	Mevcut

Görev — karar akışı

1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

1) Var mı? AHC/TPA'dan makinenin SBOM'unu isteyin; TPA PC, sürücüler ve safety cihazlarının firmware listesinde Component X aranır. **2) Sürüm etkileniyor mu?** Makinedeki sürüm 2.4, CVE'nin etkilenen aralığında mı? **3) Ulaşılabilir mi?** Zafiyetli servis ağdan/uzak erişim yolundan çağrılabiliyor mu? Makine internetten ve ofisten ayrıysa ulaşılabilirlik düşer, jump server arkasındaysa dolaylı mümkün. **Karar:** üçü de "evet" ise etkileniyorsunuz (bu örnekte: var + 2.4 etkileniyor + servis yolu açık → **etkileniyor, koşullu**). Biri "hayır" ise izlemeye alınır, CVSS 9.8 tek başına karar sebebi değildir.

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Hayır, hemen durdurmam — sömürü belirtisi yoksa. Ama **önce uzak erişimi kapatırım** (ucuz, hızlı ve ulaşılabilirliği keser). Makine yerel çalışmaya devam eder; yama planlı bakım penceresinde uygulanır. Sömürü şüphesi/belirtisi varsa (Lab 6) makine kontrollü şekilde güvenli durumda durdurulur.

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. Test: yedek/aynı konfigürasyonlu TPA PC veya sanal imaj, mümkünse AHC'nin test/onay ortamı; **canlı makinede değil**. Öncesinde program + parametre + sürücü ayar yedeği alınır, geri dönüş planı hazırlanır, üretici onayı alınır; uygulama vardiya dışı bakım penceresinde yapılır.

4 Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Yama; **sürücü/safety firmware'ini, STO/duruş parametrelerini, TPA'nın I/O veya hız/ofset işlemesini** etkiliyorsa etkiler. Anlamak için: üreticinin sürüm notu ve etki beyanı, SBOM'da "safety-related" işaretli bileşenler. Emin değilsek **etkiliyor kabul ederiz**: yama sonrası E-stop, kapı/ışık perdesi, STO ve **duruş süresi ölçümü** tekrarlanır ve sonuçlar kaydedilir.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

Uzak erişim varsayılan kapalı + yalnız jump server/VPN/MFA · zafiyetli servisin portu güvenlik duvarında kapalı · Z2'ye internet/ofis erişimi yok · USB kilidi ve uygulama beyaz listesi · TPA PC'de değişiklik/ağ izleme ve log · dosya aktarımında tarama · safety yolunun bağımsızlığının doğrulanması · **yama çıkana kadar yazılı gözden geçirme tarihi**.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur.